Guion de defensa individual — 10 minutos + 5 de preguntas

Preparado para Antonella Cuvertino; Miriam puede usarlo cambiando la presentación personal. No repartir la explicación entre ambas: la pauta evalúa dominio individual. Ensayar el texto y usar el tiempo restante de cada tramo para señalar evidencia, sin afirmar que se ejecutaron herramientas pendientes.

Diapositiva 1. Cuidarte+ — 00:00 a 00:30

Soy Antonella Cuvertino y presentaré el aseguramiento de calidad de Cuidarte+, una plataforma de información clínica. El objetivo fue contrastar requisitos con evidencia funcional, de seguridad y de calidad. Nuestra conclusión es no certificar el despliegue productivo en el estado evaluado. Mostraré los casos, los resultados y el fundamento de esta decisión.

Apoyo: señalar el punto del criterio y su límite de evidencia.

Diapositiva 2. Un sistema clínico exige más que funcionar — 00:30 a 01:10

El sistema tiene una interfaz React, una API Express y PostgreSQL. Administradores gestionan usuarios, médicos registran información y pacientes consultan sus resultados. El dato de salud es sensible: un error de autorización tiene consecuencias diferentes de un error visual. Por eso priorizamos confidencialidad e integridad, además de disponibilidad. La prueba se realizó con datos sintéticos en una base separada.

Apoyo: señalar el punto del criterio y su límite de evidencia.

Diapositiva 3. Estrategia basada en riesgos — 01:10 a 02:00

Elegimos un enfoque mixto y basado en riesgos. Desde la planificación incorporamos actores, permisos y consecuencias sobre datos clínicos. Priorizamos autorización y contraseñas; después integridad de registros y desempeño. La entrada exige casos definidos y un entorno aislado. La salida exige resolver todos los defectos críticos y graves y completar el alcance. No confundimos tener herramientas instaladas con haber demostrado sus criterios.

Apoyo: señalar el punto del criterio y su límite de evidencia.

Diapositiva 4. Tipos de prueba: qué comprueba cada uno — 02:00 a 03:05

Cada tipo responde una pregunta diferente. La prueba funcional verifica si el login acepta o rechaza las credenciales previstas. La integración verifica que la operación persista correctamente y que el documento descargado conserve sus bytes. La seguridad cambia el actor o el recurso: por ejemplo, el paciente B intenta consultar un examen de A, y un médico intenta cambiarse a administrador. La prueba de rendimiento mide tiempo bajo condiciones conocidas. Un HTTP 200 no basta para aprobar: necesitamos comprobar el efecto y compararlo con el criterio.

Apoyo: señalar el punto del criterio y su límite de evidencia.

Diapositiva 5. Casos definidos y trazabilidad — 03:05 a 04:10

El plan contiene ocho casos maestros con precondiciones, pasos, datos, resultado esperado y aceptación. Para esta ejecución automatizamos doce comprobaciones derivadas; no afirmamos que las doce equivalgan a ejecutar integralmente los ocho casos. Un ejemplo trazable es RF-3.3, borrado lógico: el caso maestro exige conservar la fila. El checkpoint ejecuta DELETE y luego consulta la base. La fila desaparece, por lo que registramos FAIL y DEF-003. La trazabilidad conecta una expectativa concreta con una observación y una decisión, sin inventar cobertura total de una ERS que no recibimos.

Apoyo: señalar resultados_api.json y la consulta de persistencia.

Diapositiva 6. Herramientas y ambiente reproducible — 04:10 a 05:00

Usamos Node.js para enviar peticiones reproducibles y consultar PostgreSQL, de modo que el resultado no dependa solo de la pantalla. Docker permitió aislar la base. SonarQube analiza el código y genera hallazgos de calidad y seguridad que requieren interpretación. El navegador aporta capturas, pero no sustituye las aserciones. La carga breve se ejecutó con solicitudes paralelas, no con JMeter. Tampoco afirmamos haber ejecutado DAST o generado cobertura LCOV: esas ampliaciones están documentadas como pendientes.

Apoyo: señalar el punto del criterio y su límite de evidencia.

Diapositiva 7. Ejecución: 12 comprobaciones reales — 05:00 a 06:00

En la suite de API se ejecutaron doce comprobaciones: seis pasaron y seis fallaron. Pasaron el login y su rechazo, validaciones, las rutas IDOR probadas, tokens inválidos y transferencia de PDF. Fallaron seis criterios de integridad, protección y permisos. Cada fila incluye esperado, obtenido y evidencia con fecha. La ejecución fue automatizada con asistencia y debemos poder explicar sus pasos. Los cinco PASS visuales del documento anterior se conservan como históricos; no se suman a estas doce ejecuciones ni prueban seguridad global.

Apoyo: señalar resultados_api.json y la consulta de persistencia.

Diapositiva 8. Defectos que bloquean el lanzamiento — 06:00 a 07:10

Clasificamos como crítico el escalamiento de privilegios porque un médico logra asignarse administrador y la base confirma el nuevo rol. También es crítico eliminar una cuenta sin autenticación: el endpoint devuelve 200 y la fila desaparece. Son comprobaciones con cuentas sintéticas. Los otros cuatro defectos son graves: contraseña en texto claro, eliminación física del examen, auditoría sin IP y demora excesiva. No se corrigió código durante la actividad; eso conserva la evidencia del estado evaluado. La severidad proviene del impacto en un sistema clínico y no de una multa supuesta.

Apoyo: señalar resultados_api.json y la consulta de persistencia.

Diapositiva 9. SonarQube: interpretar, no solo contar — 07:10 a 08:05

Estos son los valores de la exportación real de SonarQube y su Quality Gate. Los bugs apuntan a fiabilidad, los code smells a mantenibilidad y los hotspots requieren revisión contextual. Un hotspot no se declara automáticamente una vulnerabilidad. No generamos un reporte LCOV, por lo que la cobertura no demuestra pruebas instrumentadas. Además contrastamos el texto del encargo: el controlador citado para SQLi no existe y las consultas observadas usan parámetros. Reportamos solo lo que consta en el código y en las evidencias, incluso si el analizador no detecta una falla que sí confirma la API.

Apoyo: señalar la exportación y captura reales de SonarQube.

Diapositiva 10. Rendimiento y privacidad — 08:05 a 08:45

El lote de 200 solicitudes terminó sin errores HTTP, pero su p95 superó ampliamente 300 milisegundos; no certifica estabilidad prolongada. En privacidad distinguimos el régimen vigente de la Ley 19.628 y la preparación para la Ley 21.719, cuya vigencia general comienza el primero de diciembre de 2026. La aplicación de la Ley 21.663 depende del sujeto y actividad. No atribuimos una multa automática por faltar una IP ni afirmamos certificación legal integral.

Apoyo: señalar el punto del criterio y su límite de evidencia.

Diapositiva 11. Recomendaciones con evidencia — 08:45 a 09:25

Las recomendaciones siguen los hallazgos. Primero debemos cerrar acciones anónimas y escalamiento de rol, con autorización del servidor antes de modificar datos. Después proteger contraseñas, conservar registros y hacer consistente la auditoría. Retiramos las demoras del entorno objetivo y medimos de nuevo. Cada corrección debe acompañarse de un retest y pruebas negativas, además de regresión. Es una decisión ética proteger al paciente y comunicar con precisión lo que falta, en lugar de declarar seguro un sistema por una pantalla que funciona.

Apoyo: señalar el punto del criterio y su límite de evidencia.

Diapositiva 12. Dictamen: NO CERTIFICADO — 09:25 a 10:00

La conclusión es no certificado para producción. Tenemos dos defectos críticos y cuatro graves abiertos, por lo que no se cumple la salida definida. El expediente entrega los casos, los resultados, los defectos y las recomendaciones para que otro equipo pueda reproducirlos. La certificación podrá reevaluarse con evidencia de corrección y un alcance completo. Esta conclusión es técnica y académica, y protege el tratamiento responsable de información clínica.

Apoyo: señalar el punto del criterio y su límite de evidencia.

Preguntas probables y respuestas para los 5 minutos

¿Por qué no certificado si seis pruebas pasaron? Porque el criterio de salida exige cero críticos o graves abiertos; el éxito parcial no compensa una acción destructiva anónima o el escalamiento de privilegios.

¿SonarQube ejecuta todas las pruebas? No. Analiza código estáticamente; no reemplaza pruebas funcionales, integración, IDOR ni carga. Sus hotspots requieren revisión.

¿Cómo demostraron que el borrado no era lógico? Se creó un examen sintético, se llamó DELETE como administrador y se consultó la tabla: quedó sin la fila. La captura del modal no bastaba.

¿Qué diferencia hay entre RBAC e IDOR? RBAC valida la operación según rol; IDOR exige además comprobar que ese recurso corresponde al actor. Un paciente puede tener permiso de lectura y aun así no poder leer el examen de otro.

¿Cómo se confirmó el escalamiento? El médico envió un cambio de su propio rol; la API respondió 200 y usuario_roles quedó con admin. No se inferió solo del código.

¿Por qué la falta de IP no significa multa automática? Es una desviación del criterio técnico de trazabilidad. Para una infracción legal hay que determinar obligaciones, sujeto, conducta y procedimiento. La Ley 21.663 no obliga literalmente a una tabla con un nombre específico.

¿La Ley 21.719 ya rige? A la fecha de revisión, 20-10-2026, su vigencia general es futura: 01-12-2026. Se distingue del régimen vigente de Ley 19.628 y se prepara la transición.

¿200 solicitudes son 200 usuarios sostenidos? No. Se lanzó un lote breve de 200 peticiones concurrentes; no incluye sesiones clínicas sostenidas ni renderizado. No reemplaza JMeter de 10 minutos o un estudio de capacidad.

¿Por qué hay cobertura cero o no disponible si se probaron endpoints? Porque no se produjo LCOV de ejecución instrumentada del código. Casos ejecutados, requisitos cubiertos y líneas cubiertas son métricas distintas.

¿Se detectó SQLi en examenes.controller.js? No se confirmó: ese archivo no existe en el código recibido. Se revisó examenes.js y se informaron solo hallazgos respaldados. No se creó un resultado para coincidir con el encargo.

¿Qué hizo cada integrante? Explicar solo contribuciones efectivamente revisadas y realizadas. Los roles del plan son una asignación propuesta; la ejecución técnica registrada fue automatizada con asistencia. Ambas deben dominar todo el expediente.

¿Qué falta para cerrar? Corregir seis defectos, retestar y ampliar a ERS, unitarias/cobertura, DAST, WCAG y carga sostenida. No se declara aprobado algo por haber preparado una guía.

Ensayo y contingencia

Abrir el PDF de diapositivas antes de la clase y el JSON de resultados. Ensayar con cronómetro: 10 minutos, luego 5 de preguntas. Mantener una copia local del ZIP. Si falla Docker o Internet, mostrar las exportaciones y capturas guardadas; explicar que la evidencia corresponde a la versión analizada. No improvisar pruebas destructivas con datos reales durante la defensa.